

Тест по БАЗС

1 Вопрос:

Кто является основным ответственным за определение уровня классификации информации?

Варианты ответа:

1. Руководитель среднего звена
2. Высшее руководство
3. Владелец
4. Пользователь

2 Вопрос:

Какая категория является наиболее рискованной для компании с точки зрения вероятного мошенничества и нарушения безопасности?

Варианты ответа:

1. Сотрудники
2. Хакеры
3. Атакующие
4. Контрагенты (лица, работающие по договору)

3 Вопрос:

Если различным группам пользователей с различным уровнем доступа требуется доступ к одной и той же информации, какое из указанных ниже действий следует предпринять руководству?

Варианты ответа:

1. Снизить уровень безопасности этой информации для обеспечения ее доступности и удобства использования
2. Требовать подписания специального разрешения каждый раз, когда человеку требуется доступ к этой информации
3. Улучшить контроль за безопасностью этой информации
4. Снизить уровень классификации этой информации

4 Вопрос:

Что самое главное должно продумать руководство при классификации данных?

Варианты ответа:

1. Типы сотрудников, контрагентов и клиентов, которые будут иметь доступ к данным
2. Необходимый уровень доступности, целостности и конфиденциальности
3. Оценить уровень риска и отменить контрмеры
4. Управление доступом, которое должно защищать данные

5 Вопрос:

Кто в конечном счете несет ответственность за гарантии того, что данные классифицированы и защищены?

Варианты ответа:

1. Владельцы данных
2. Пользователи
3. Администраторы
4. Руководство

6 Вопрос:

Что такое процедура?

Варианты ответа:

1. Правила использования программного и аппаратного обеспечения в компании
2. Пошаговая инструкция по выполнению задачи
3. Руководство по действиям в ситуациях, связанных с безопасностью, но не описанных в стандартах
4. Обязательные действия

7 Вопрос:

Какой фактор наиболее важен для того, чтобы быть уверенным в успешном обеспечении безопасности в компании?

Варианты ответа:

1. Поддержка высшего руководства
2. Эффективные защитные меры и методы их внедрения
3. Актуальные и адекватные политики и процедуры безопасности
4. Проведение тренингов по безопасности для всех сотрудников

8 Вопрос:

Когда целесообразно не предпринимать никаких действий в отношении выявленных рисков?

Варианты ответа:

1. Никогда. Для обеспечения хорошей безопасности нужно учитывать и снижать все риски
2. Когда риски не могут быть приняты во внимание по политическим соображениям
3. Когда необходимые защитные меры слишком сложны
4. Когда стоимость контрмер превышает ценность актива и потенциальные потери

9 Вопрос:

Что такое политики безопасности?

Варианты ответа:

1. Пошаговые инструкции по выполнению задач безопасности
2. Общие руководящие требования по достижению определенного уровня безопасности
3. Широкие, высокоуровневые заявления руководства
4. Детализированные документы по обработке инцидентов безопасности

10 Вопрос:

Какая из приведенных техник является самой важной при выборе конкретных защитных мер?

Варианты ответа:

1. Анализ рисков
2. Анализ затрат / выгоды
3. Результаты ALE
4. Выявление уязвимостей и угроз, являющихся причиной риска

11 Вопрос:

Что лучше всего описывает цель расчета ALE?

Варианты ответа:

1. Количественно оценить уровень безопасности среды
2. Оценить возможные потери для каждой контрмеры
3. Количественно оценить затраты / выгоды
4. Оценить потенциальные потери от угрозы в год

12 Вопрос:

Тактическое планирование – это:

Варианты ответа:

1. Среднесрочное планирование
2. Долгосрочное планирование
3. Ежедневное планирование
4. Планирование на 6 месяцев

13 Вопрос:

Что является определением воздействия (Exposure) на безопасность?

Варианты ответа:

1. Нечто, приводящее к ущербу от угрозы
2. Любая потенциальная опасность для информации или систем
3. Любой недостаток или отсутствие информационной безопасности
4. Потенциальные потери от угрозы

14 Вопрос:

Эффективная программа безопасности требует сбалансированного применения:

Варианты ответа:

1. Технических и нетехнических методов
2. Контрмер и защитных механизмов
3. Физической безопасности и технических средств защиты
4. Процедур безопасности и шифрования

15 Вопрос:

Функциональность безопасности определяет ожидаемую работу механизмов безопасности, а гарантии определяют:

Варианты ответа:

1. Внедрение управления механизмами безопасности
2. Классификацию данных после внедрения механизмов безопасности
3. Уровень доверия, обеспечиваемый механизмом безопасности
4. Соотношение затрат / выгод

16 Вопрос:

Какое утверждение является правильным, если взглянуть на разницу в целях безопасности для коммерческой и военной организации?

Варианты ответа:

1. Только военные имеют настоящую безопасность
2. Коммерческая компания обычно больше заботится о целостности и доступности данных, а военные – о конфиденциальности
3. Военным требуется больший уровень безопасности, т.к. их риски существенно выше
4. Коммерческая компания обычно больше заботится о доступности и конфиденциальности данных, а военные – о целостности

17 Вопрос:

Как рассчитать остаточный риск?

Варианты ответа:

1. Угрозы x Риски x Ценность актива
2. (Угрозы x Ценность актива x Уязвимости) x Риски
3. $SLE \times \text{Частоту} = ALE$
4. (Угрозы x Уязвимости x Ценность актива) x Недостаток контроля

18 Вопрос:

Что из перечисленного не является целью проведения анализа рисков?

Варианты ответа:

1. Делегирование полномочий
2. Количественная оценка воздействия потенциальных угроз
3. Выявление рисков
4. Определение баланса между воздействием риска и стоимостью необходимых контрмер

19 Вопрос:

Что из перечисленного не является задачей руководства в процессе внедрения и сопровождения безопасности?

Варианты ответа:

1. Поддержка
2. Выполнение анализа рисков
3. Определение цели и границ
4. Делегирование полномочий

20 Вопрос:

Почему при проведении анализа информационных рисков следует привлекать к этому специалистов из различных подразделений компании?

Варианты ответа:

1. Чтобы убедиться, что проводится справедливая оценка
2. Это не требуется. Для анализа рисков следует привлекать небольшую группу специалистов, не являющихся сотрудниками компании, что позволит обеспечить беспристрастный и качественный анализ
3. Поскольку люди в различных подразделениях лучше понимают риски в своих подразделениях и смогут предоставить максимально полную и достоверную информацию для анализа
4. Поскольку люди в различных подразделениях сами являются одной из причин рисков, они должны быть ответственны за их оценку

21 Вопрос:

Что является наилучшим описанием количественного анализа рисков?

Варианты ответа:

1. Анализ, основанный на сценариях, предназначенный для выявления различных угроз безопасности
2. Метод, используемый для точной оценки потенциальных потерь, вероятности потерь и рисков
3. Метод, сопоставляющий денежное значение с каждым компонентом оценки рисков
4. Метод, основанный на суждениях и интуиции

22 Вопрос:

Почему количественный анализ рисков в чистом виде не достижим?

Варианты ответа:

1. Он достижим и используется
2. Он присваивает уровни критичности. Их сложно перевести в денежный вид.
3. Это связано с точностью количественных элементов
4. Количественные измерения должны применяться к качественным элементам

23 Вопрос:

Если используются автоматизированные инструменты для анализа рисков, почему все равно требуется так много времени для проведения анализа?

Варианты ответа:

1. Много информации нужно собрать и ввести в программу
2. Руководство должно одобрить создание группы
3. Анализ рисков не может быть автоматизирован, что связано с самой природой оценки
4. Множество людей должно одобрить данные

24 Вопрос:

Какой из следующих законодательных терминов относится к компании или человеку, выполняющему необходимые действия, и используется для определения обязательств?

Варианты ответа:

1. Стандарты
2. Должный процесс (Due process)
3. Должная забота (Due care)
4. Снижение обязательств

25 Вопрос:

Что такое CobiT и как он относится к разработке систем информационной безопасности и программ безопасности?

Варианты ответа:

1. Список стандартов, процедур и политик для разработки программы безопасности
2. Текущая версия ISO 17799
3. Структура, которая была разработана для снижения внутреннего мошенничества в компаниях
4. Открытый стандарт, определяющий цели контроля

26 Вопрос:

Из каких четырех доменов состоит CobiT?

Варианты ответа:

1. Планирование и Организация, Приобретение и Внедрение, Эксплуатация и Сопровождение, Мониторинг и Оценка
2. Планирование и Организация, Поддержка и Внедрение, Эксплуатация и Сопровождение, Мониторинг и Оценка
3. Планирование и Организация, Приобретение и Внедрение, Сопровождение и Покупка, Мониторинг и Оценка
4. Приобретение и Внедрение, Эксплуатация и Сопровождение, Мониторинг и Оценка

27 Вопрос:

Что представляет собой стандарт ISO/IEC 27799?

Варианты ответа:

1. Стандарт по защите персональных данных о здоровье
2. Новая версия BS 17799
3. Определения для новой серии ISO 27000
4. Новая версия NIST 800-60

28 Вопрос:

CobiT был разработан на основе структуры COSO. Что является основными целями и задачами COSO?

Варианты ответа:

1. COSO – это подход к управлению рисками, который относится к контрольным объектам и бизнес-процессам
2. COSO относится к стратегическому уровню, тогда как CobiT больше направлен на операционный уровень
3. COSO учитывает корпоративную культуру и разработку политик
4. COSO – это система отказоустойчивости

29 Вопрос:

OCTAVE, NIST 800-30 и AS/NZS 4360 являются различными подходами к реализации управления рисками в компаниях. В чем заключаются различия между этими методами?

Варианты ответа:

1. NIST и OCTAVE являются корпоративными
2. NIST и OCTAVE ориентирован на ИТ
3. AS/NZS ориентирован на ИТ
4. NIST и AS/NZS являются корпоративными

30 Вопрос:

Какой из следующих методов анализа рисков пытается определить, где вероятнее всего произойдет сбой?

Варианты ответа:

1. Анализ связующего дерева
2. AS/NZS
3. NIST
4. Анализ сбоев и дефектов

31 Вопрос:

Что было разработано, чтобы помочь странам и их правительствам построить законодательство по защите персональных данных похожим образом?

Варианты ответа:

1. Безопасная OECD
2. ISO\IEC
3. OECD
4. CPTED

32 Вопрос:

Символы шифруемого текста перемещаются по определенным правилам внутри шифруемого блока этого текста, это метод:

Варианты ответа:

1. гаммирования;
2. подстановки;
3. кодирования;
4. перестановки;
5. аналитических преобразований.
6. Символы шифруемого текста заменяются другими символами, взятыми из одного или нескольких алфавитов, это метод:
7. гаммирования;
8. подстановки;

33 Вопрос:

Символы шифруемого текста преобразуются по определённым правилам внутри шифруемого блока текста, это метод:

Варианты ответа:

1. кодирования;
2. перестановки;
3. аналитических преобразований.

34 Вопрос:

Символы шифруемого текста последовательно складываются с символами некоторой специальной последовательности, это метод:

Варианты ответа:

1. гаммирования;
2. подстановки;
3. кодирования;
4. перестановки;
5. аналитических преобразований.

35 Вопрос:

Защита информации от утечки – это деятельность по предотвращению:

Варианты ответа:

1. получения защищаемой информации заинтересованным субъектом с нарушением установленных правовыми документами или собственником, владельцем информации прав или правил доступа к защищаемой информации;
2. воздействия с нарушением установленных прав и/или правил на изменение информации, приводящего к искажению, уничтожению, копированию, блокированию доступа к информации, а также к утрате, уничтожению или сбою функционирования носителя информации;
3. воздействия на защищаемую информацию ошибок пользователя информацией, сбоя технических и программных средств информационных систем, а также природных явлений;
4. неконтролируемого распространения защищаемой информации от ее разглашения, несанкционированного доступа;
5. несанкционированного доведения защищаемой информации до неконтролируемого количества получателей информации.

36 Вопрос:

Защита информации это:

Варианты ответа:

1. процесс сбора, накопления, обработки, хранения, распределения и поиска информации;
2. преобразование информации, в результате которого содержание информации становится непонятным для субъекта, не имеющего доступа;
3. получение субъектом возможности ознакомления с информацией, в том числе при помощи технических средств;
4. совокупность правил, регламентирующих порядок и условия доступа субъекта к информации и ее носителям;
5. деятельность по предотвращению утечки информации, несанкционированных и непреднамеренных воздействий на неё.

37 Вопрос:

Естественные угрозы безопасности информации вызваны:

Варианты ответа:

1. деятельностью человека;
2. ошибками при проектировании АСОИ, ее элементов или разработке программного обеспечения;
3. воздействиями объективных физических процессов или стихийных природных явлений, независимых от человека;
4. корыстными устремлениями злоумышленников;
5. ошибками при действиях персонала.

38 Вопрос:

Искусственные угрозы безопасности информации вызваны:

Варианты ответа:

1. деятельностью человека;
2. ошибками при проектировании АСОИ, ее элементов или разработке программного обеспечения;
3. воздействиями объективных физических процессов или стихийных природных явлений, независимых от человека;
4. корыстными устремлениями злоумышленников;
5. ошибками при действиях персонала.

39 Вопрос:

К основным непреднамеренным искусственным угрозам АСОИ относится:

Варианты ответа:

1. физическое разрушение системы путем взрыва, поджога и т.п.;
2. перехват побочных электромагнитных, акустических и др. излучений устройств и линий связи;
3. изменение режимов работы устройств или программ, забастовка, саботаж персонала, постановка мощных активных помех и т.п.;
4. чтение остаточной информации из оперативной памяти и с внешних запоминающих устройств;
5. неумышленные действия, приводящие к частичному или полному отказу системы, или разрушению аппаратных, программных, информационных ресурсов системы.

40 Вопрос:

К посторонним лицам нарушителям информационной безопасности относится:

Варианты ответа:

1. представители организаций, взаимодействующих по вопросам обеспечения жизнедеятельности организации;
2. персонал, обслуживающий технические средства;
3. технический персонал, обслуживающий здание;
4. пользователи;
5. сотрудники службы безопасности.
6. представители конкурирующих организаций.
7. лица, нарушившие пропускной режим;

41 Вопрос:

Спам, который имеет цель опорочить ту или иную фирму, компанию, политического кандидата и т. п:

Варианты ответа:

1. черный пиар;
2. фишинг;
3. нигерийские письма;
4. источник слухов;
5. пустые письма.

42 Вопрос:

Спам распространяет поддельные сообщения от имени банков или финансовых компаний, целью которых является сбор логинов, паролей и пин-кодов пользователей:

Варианты ответа:

1. черный пиар;
2. фишинг;
3. нигерийские письма;
4. источник слухов;
5. пустые письма.

43 Вопрос:

Антивирус обеспечивает поиск вирусов в оперативной памяти, на внешних носителях путем подсчета и сравнения с эталоном контрольной суммы:

Варианты ответа:

1. детектор;
2. доктор;
3. сканер;
4. ревизор;
5. сторож.

44 Вопрос:

Антивирус не только находит зараженные вирусами файлы, но и "лечит" их, т.е. удаляет из файла тело программы вируса, возвращая файлы в исходное состояние:

Варианты ответа:

1. детектор;
2. доктор;
3. сканер;
4. ревизор;
5. сторож.

45 Вопрос:

Антивирус запоминает исходное состояние программ, каталогов и системных областей диска когда компьютер не заражен вирусом, а затем периодически или по команде пользователя сравнивает текущее состояние с исходным:

Варианты ответа:

1. детектор;
2. доктор;
3. сканер;
4. ревизор;
5. сторож.

46 Вопрос:

Антивирус представляет собой небольшую резидентную программу, предназначенную для обнаружения подозрительных действий при работе компьютера, характерных для вирусов:

Варианты ответа:

1. детектор;
2. доктор;
3. сканер;
4. ревизор;
5. сторож.

47 Вопрос:

Активный перехват информации — это перехват, который:

Варианты ответа:

1. заключается в установке подслушивающего устройства в аппаратуру средств обработки информации;
2. основан на фиксации электромагнитных излучений, возникающих при функционировании средств компьютерной техники и коммуникаций;
3. неправомерно использует технологические отходы информационного процесса;
4. осуществляется путем использования оптической техники;
5. осуществляется с помощью подключения к телекоммуникационному оборудованию компьютера.

48 Вопрос:

Перехват, который заключается в установке подслушивающего устройства в аппаратуру средств обработки информации называется:

Варианты ответа:

1. активный перехват;
2. пассивный перехват;
3. аудиоперехват;
4. видеоперехват;
5. просмотр мусора.

49 Вопрос:

Перехват, который основан на фиксации электромагнитных излучений, возникающих при функционировании средств компьютерной техники и коммуникаций называется:

Варианты ответа:

1. активный перехват;
2. пассивный перехват;
3. аудиоперехват;
4. видеоперехват;
5. 5.просмотр мусора.

50 Вопрос:

Перехват, который осуществляется путем использования оптической техники называется:

Варианты ответа:

1. активный перехват;
2. пассивный перехват;
3. аудиоперехват;
4. видеоперехват;
5. просмотр мусора.

51 Вопрос:

К внутренним нарушителям информационной безопасности относится:

Варианты ответа:

1. клиенты;
2. пользователи системы;
3. посетители;
4. любые лица, находящиеся внутри контролируемой территории;
5. представители организаций, взаимодействующих по вопросам обеспечения жизнедеятельности организации.
6. персонал, обслуживающий технические средства.
7. сотрудники отделов разработки и сопровождения ПО;
8. технический персонал, обслуживающий здание